



Windows Authentication Concepts

Ing. Ondřej Ševeček | GOPAS a.s. |

MCSM:Directory2012 | MCM:Directory2008 | MVP:Enterprise Security | CEH: Certified Ethical Hacker | CHFI: Computer Hacking Forensic Investigator | CISA |

ondrej@sevecek.com | www.sevecek.com |

GOPAS: info@gopas.cz | www.gopas.cz | www.facebook.com/P.S.GOPAS

Operating systems

- Active Directory domain environment
 - Windows 2000 DFL+
- Windows 2000+ machines
- RODC
- AD trusts
- AAD synchronized accounts (AAD Connect)
 - Windows Hello for Business (WHB)

Authenticated scenarios

- Local (interactive) logon
- Remote desktop logon
- AD LDAP queries
- File sharing
- Remote administration over SMB, DCOM
- WMI, PowerShell Remoting (WinRM)
- AD CS certificate enrollment
- DNS secure dynamic update
- IIS
- SQL server, Exchange, SharePoint, Lync, ...

Anonymous scenarios

- ping
- DNS queries
- DHCP queries
- NetBIOS name resolution
- LLMNR

- computer browsing
- messenger
- enumeration of user accounts and shares on Windows NT 4.0
- anonymous LDAP queries if enabled
- anonymous SMB access if enabled

SSO (single-sign-on)

- Minimize use of secure authentication information
 - ISO/IEC 27001, NIST 800-53, ...
- Limits password/PIN exposure
- Limits user's incentives to store passwords on local systems
 - or write them down

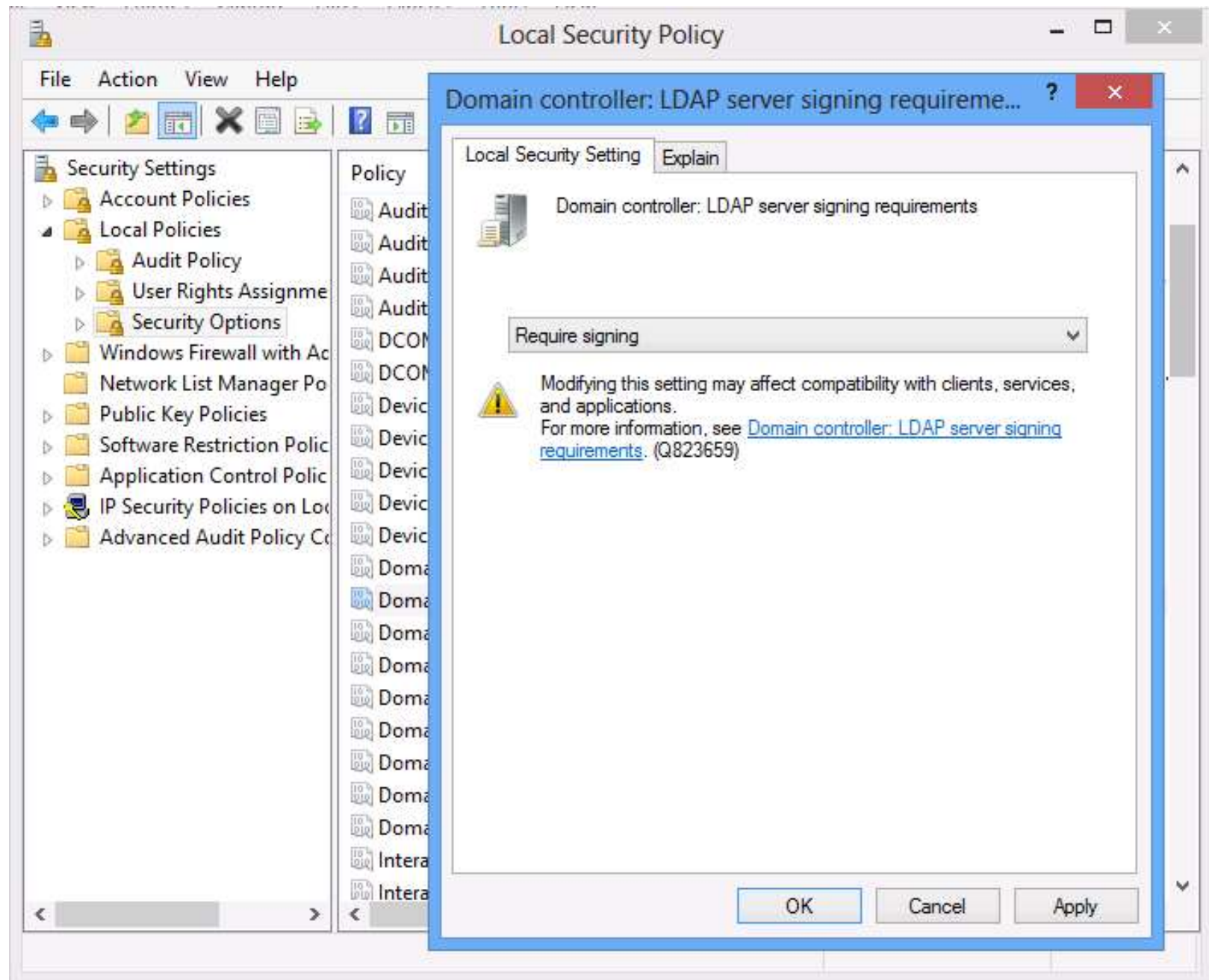
Channel protection

- TLS/SSL
 - HTTPS, RDP, LDAPS, ...
- IPSec
- SASL / GSS-API
 - integrated API for **signing** (message authenticity) and **sealing** (encryption) of the channel
 - keys generated by the authentication method in use
 - SMB signing, SMBv3 encryption, LDAP signing, DCOM, WMI, PPTP MPPE, SQL, AD CS, Exchange RPC, AD replication

PowerShell

```
gwmi Win32_LogicalDisk -Comp gps-data1 -Authentication PacketPrivacy  
gwmi Win32_LogicalDisk -Comp gps-data1 -Authentication PacketIntegrity
```

Domain controllers: LDAP server signing requirements





Network security: LDAP client encryption requirements

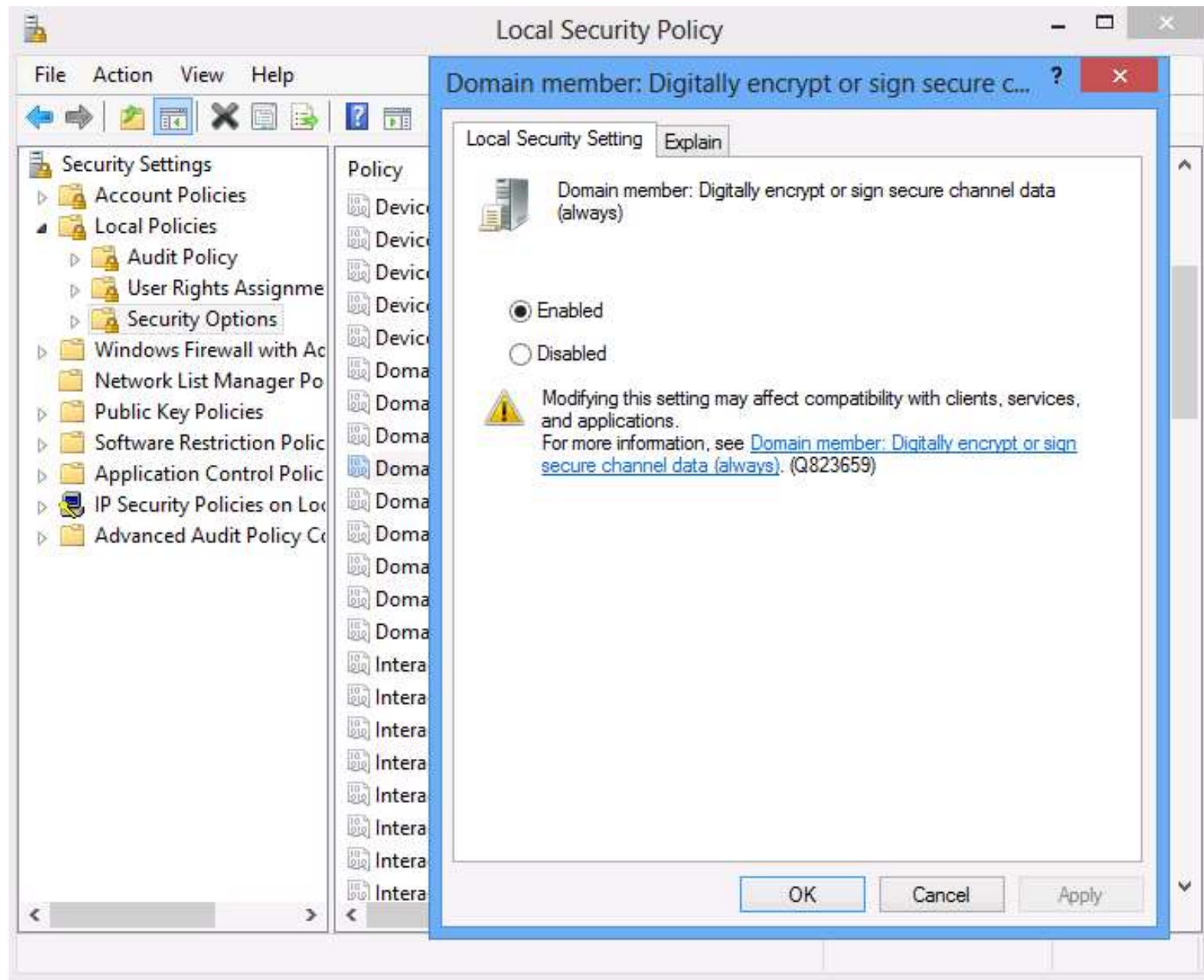
The screenshot shows the Windows Local Security Policy console. The left pane displays the 'Security Settings' tree with 'Local Policies' expanded and 'Security Options' selected. The right pane shows a list of policies, with 'Network security: LDAP client encryption requirements' highlighted. A context menu is open over this policy, showing the 'Local Security Setting' tab and the 'Explain' button. The 'Explain' dialog box is displayed, showing the policy name and a dropdown menu with the following options: 'Require sealing' (selected), 'None', 'Negotiate sealing', and 'Require sealing'.

Policy	Security Setting
Network security: Force logoff when logon hours expire	Disabled
Network security: LAN Manager authentication level	Not Defined
Network security: LDAP client encryption requirements	Require sealing
Network security: LDAP client signing requirements	Negotiate signing
Network security: Minimum session security for NTLM S...	Require 128-bit encr...

Local Security Setting Explain

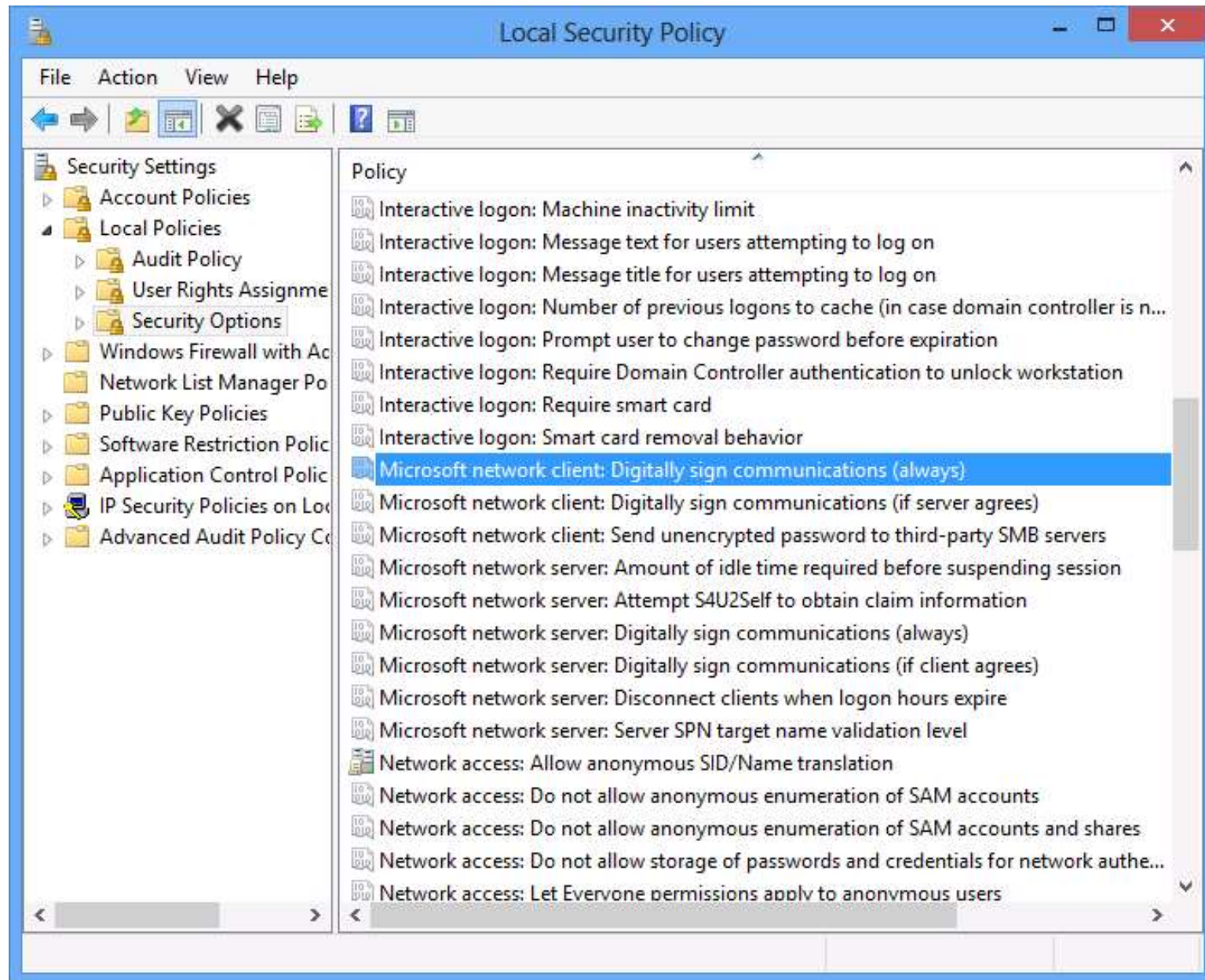
Network security: LDAP client encryption requirements

Require sealing
None
Negotiate sealing
Require sealing



Microsoft network client: Digitally sign communications

Microsoft network server: Digitally sign communications



AD DS LDAP notes

- Anonymous logon enabled by default with first forest DC 2003 and older
 - CN=Directory Service,CN=Windows NT,CN=Services,CN=Configuration,DC=gopas,DC=virtual
 - **dSHeuristics** =2 (seventh 2 = such as 0000002)
 - **Pre-Windows 2000 Compatible Access** group contains **Anonymous Logon**
- Simple bind over clear-channel can be disabled
 - **Domain Controller: LDAP server signing requirements** = Require signing

Authentication methods in Windows

- Password
 - single factor
 - stored in AD or local SAM database as hash
 - NTLM, Kerberos, HTTP basic, AD LDAP simple bind, Digest
- Certificate
 - single factor if not stored in smart card
 - PKI certificate's private key mapped to AD user account
 - TLS/SSL client certificate authentication (SCHANNEL)
- Smart card (Windows Hello for Business)
 - smart card / token / TPM
 - multi factor
 - PKI certificate's private key mapped to AD user account
 - AD Kerberos only

Logins are "public" (paste next slide first)

```
$domainSID = Get-PrimaryDomainSID
```

```
(500..10000) | % {
```

```
    $user = New-Object  
    Security.Principal.SecurityIdentifier $domainSID-$_  
    $errorActionPreference = 'SilentlyContinue'
```

```
$user.Translate([Type]::GetType('System.Security.Principal.NTAccount')).Value  
    $errorActionPreference = 'Continue'  
}
```

Utility function for the previous script

```
function global:Get-PrimaryDomainSID ()
{
    # Note: this script obtains SID of the primary AD domain for the local computer. It
    works both
    #         if the local computer is a domain member (DomainRole = 1 or DomainRole = 3)
    #         or if the local computer is a domain controller (DomainRole = 4 or DomainRole =
    4).
    #         The code works even under local user account and does not require calling user
    #         to be domain account. This should also work on any AD domain regardless of
    language
    #         mutation because, hopefully, the krbtgt account has always the same name

    [string] $domainSID = $null

    [int] $domainRole = gwmi Win32_ComputerSystem | Select -Expand DomainRole
    [bool] $isDomainMember = ($domainRole -ne 0) -and ($domainRole -ne 2)

    if ($isDomainMember) {

        [string] $domain = gwmi Win32_ComputerSystem | Select -Expand Domain
        [string] $krbtgtSID = (New-Object Security.Principal.NTAccount
        $domain\krbtgt).Translate([Security.Principal.SecurityIdentifier]).Value
        $domainSID = $krbtgtSID.SubString(0, $krbtgtSID.LastIndexOf('-'))
    }

    return $domainSID
}
```


Multifactor authentication

- Two or more independent things to be used
 - only smart card logon (PKINIT) in Windows natively
- Must **know** the password (PIN)
- Must **have** the card
 - cannot be copied
 - is not flash disk
 - contains cryptographic processor
 - must communicate with the processor in order to have
 - ◆ anything de/encrypted
 - ◆ private key im/exported
 - usually have PIN and "master" PIN

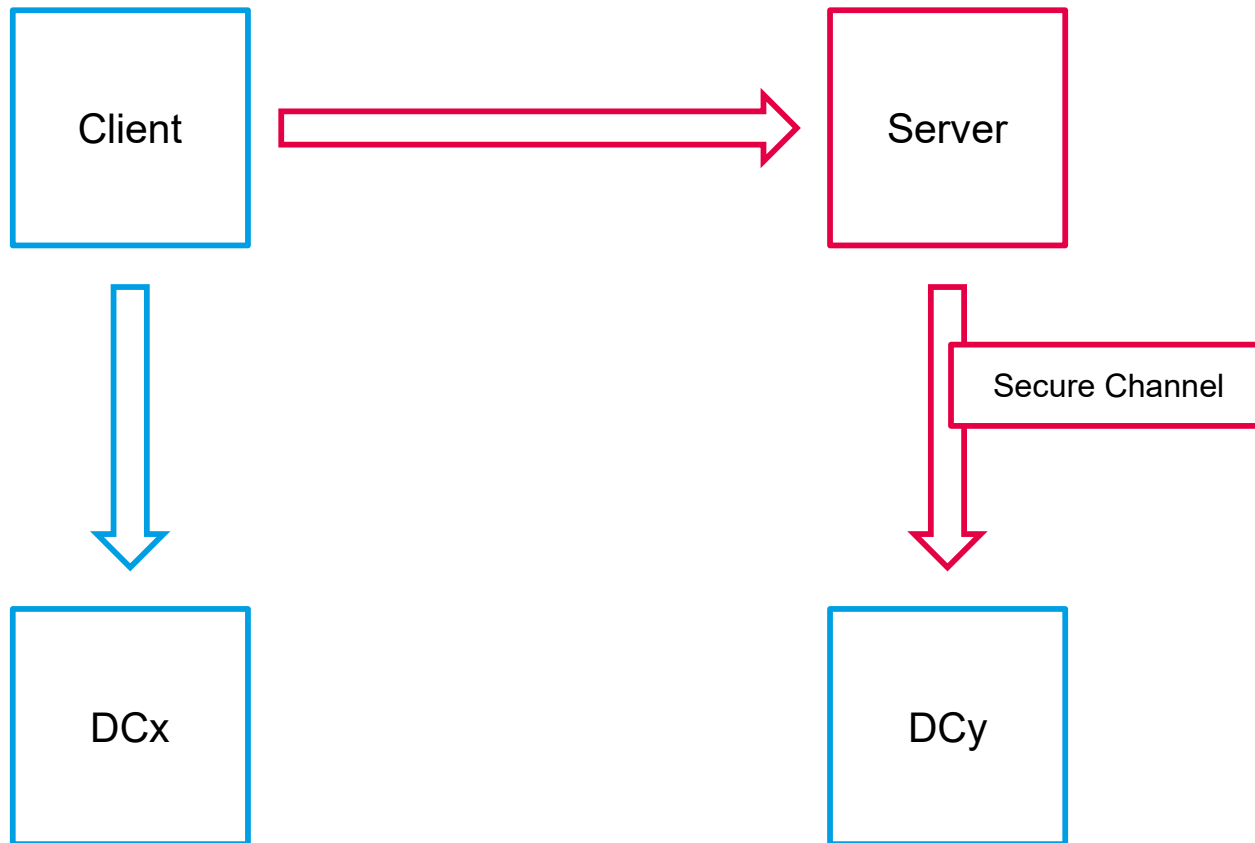
Other multifactor authentication in Windows

- Thumprint
- RSA SecureId calculator
- Retina?
- SMS verification
- APP verification
- Always map to a **password** or **PKINIT** in Windows
 - AD does not authenticate with anything else
 - SecureId for example synchronizes user passwords from AD to its own central store

Network authentication against AD

- Basic
 - full-text password sent over clear/encrypted channel
 - HTTP/SMTP/POP3/IMAP4 basic, LDAP simple bind, RDP, RDP SSO, CredSSP, forms-based/cookie-based, RADIUS PAP
 - does not have SSO and SASL
- NTLM
 - hashed password with random challenge
 - LM, NTLMv1/MS-CHAP, NTLMv2/MS-CHAPv2
- Kerberos
 - hashed password encrypted timestamp
 - private key signature of timestamp (PKINIT)
- TLS/SSL client certificate authentication
 - private key signature of server's challenge
 - HTTPS, EAP-TLS, AD FS
- Digest
 - MD5 hashed password with random challenge
 - HTTP digest, CHAP, LDAP digest

Network authentication



Secure channel and NLTEST

C:\

Administrator: C:\Windows\system32\cmd.exe

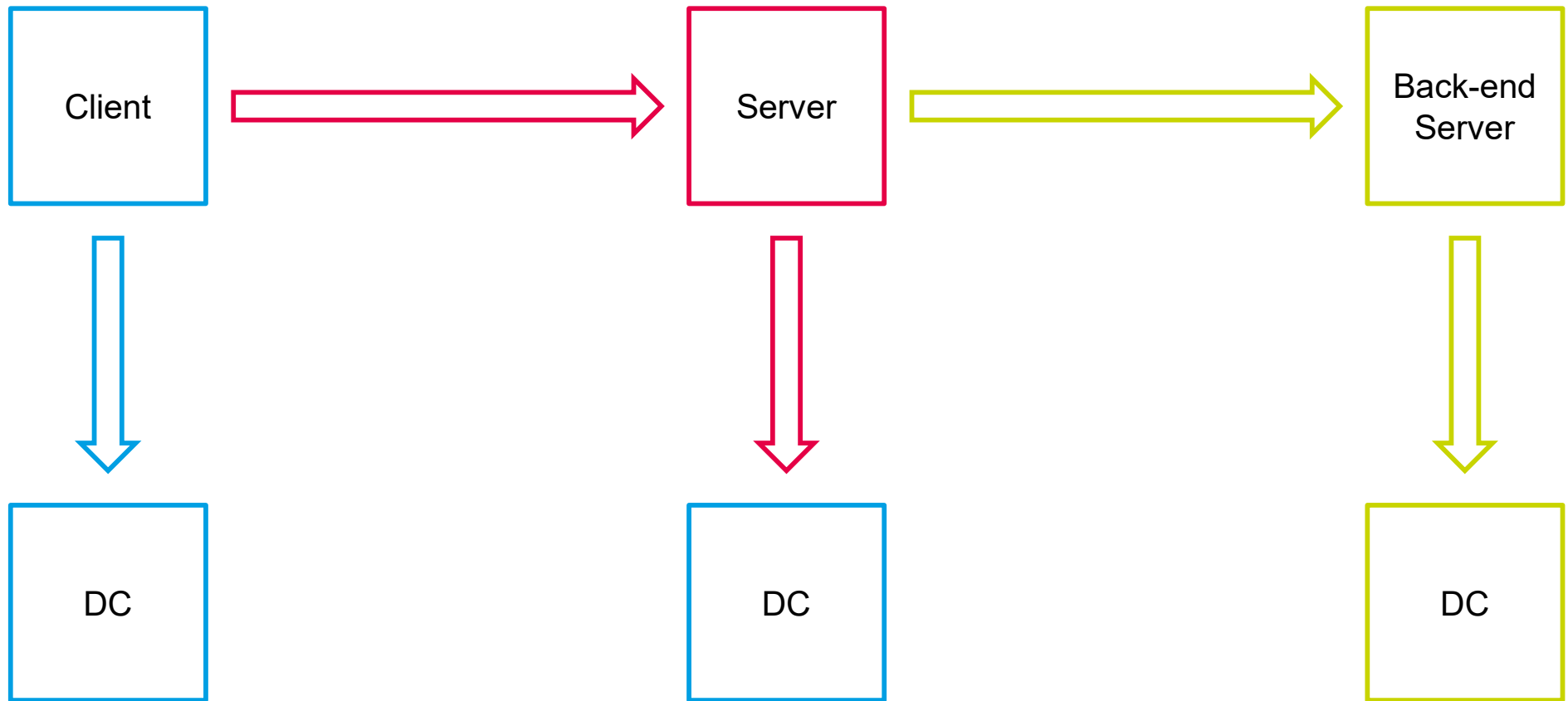
```
C:\Users\db-admin>nltest /sc_query:gps
Flags: 30 HAS_IP HAS_TIMESERV
Trusted DC Name \\GPS-DC2.gopas.virtual
Trusted DC Connection Status Status = 0 0x0 NERR_Success
The command completed successfully
```

```
C:\Users\db-admin>nltest /sc_verify:gps
Flags: b0 HAS_IP HAS_TIMESERV
Trusted DC Name \\GPS-DC2.gopas.virtual
Trusted DC Connection Status Status = 0 0x0 NERR_Success
Trust Verification Status = 0 0x0 NERR_Success
The command completed successfully
```

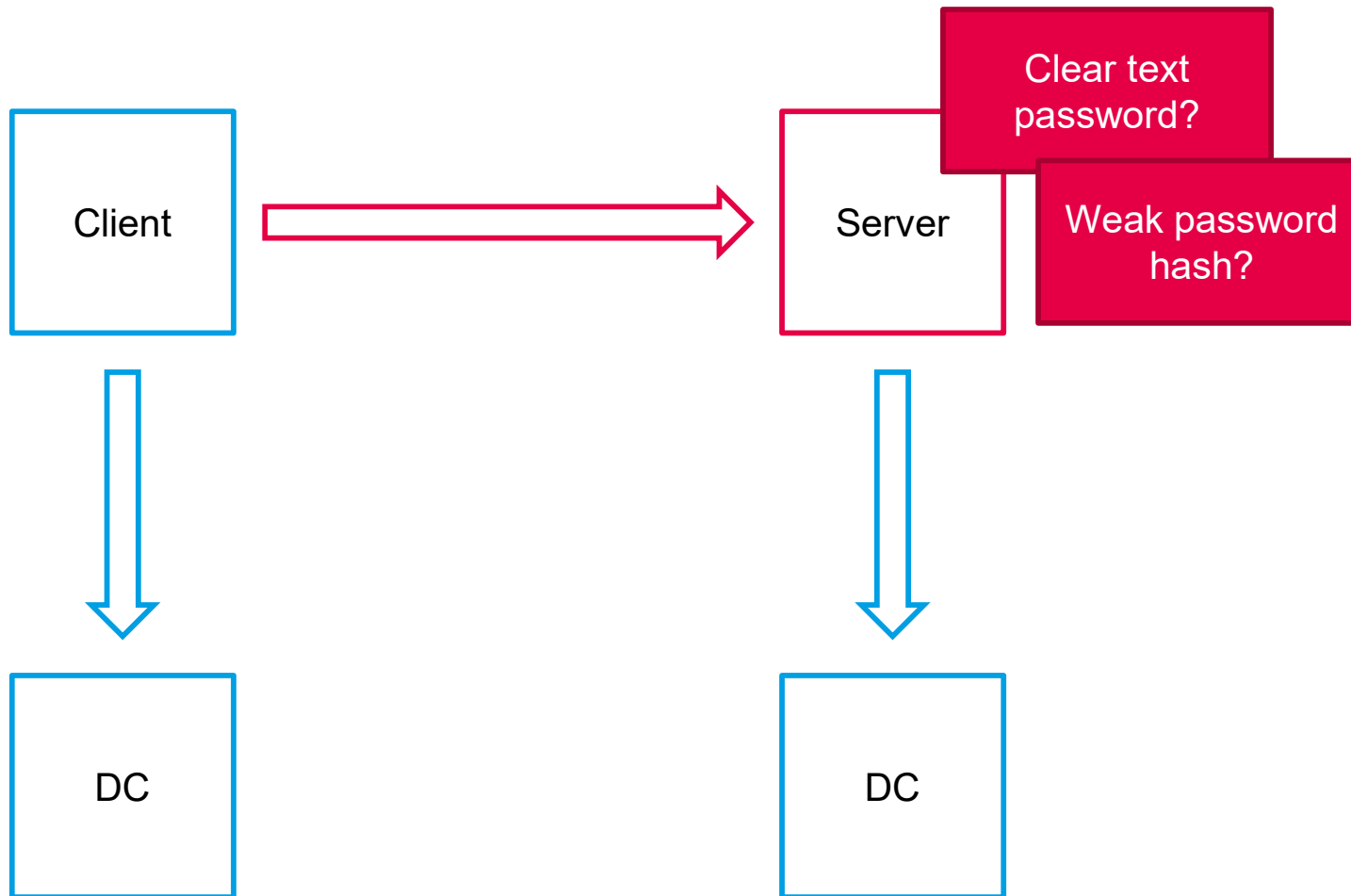
```
C:\Users\db-admin>nltest /sc_reset:gps
Flags: 30 HAS_IP HAS_TIMESERV
Trusted DC Name \\GPS-DC2.gopas.virtual
Trusted DC Connection Status Status = 0 0x0 NERR_Success
The command completed successfully
```

```
C:\Users\db-admin>nltest /sc_reset:gps
Flags: 30 HAS_IP HAS_TIMESERV
Trusted DC Name \\GPS-DC1.gopas.virtual
Trusted DC Connection Status Status = 0 0x0 NERR_Success
The command completed successfully
```

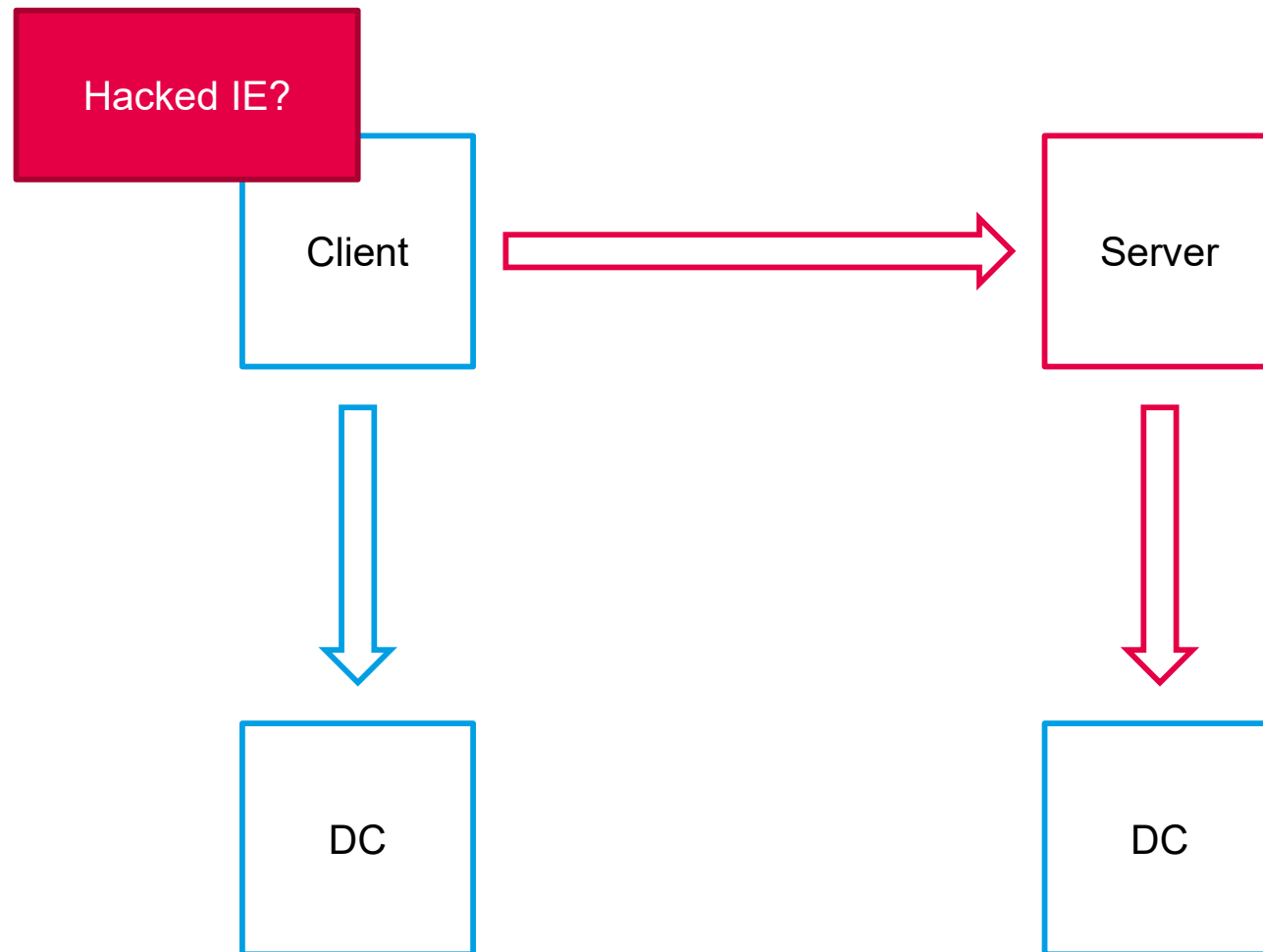
Delegation (double-hop)



Network authentication risks



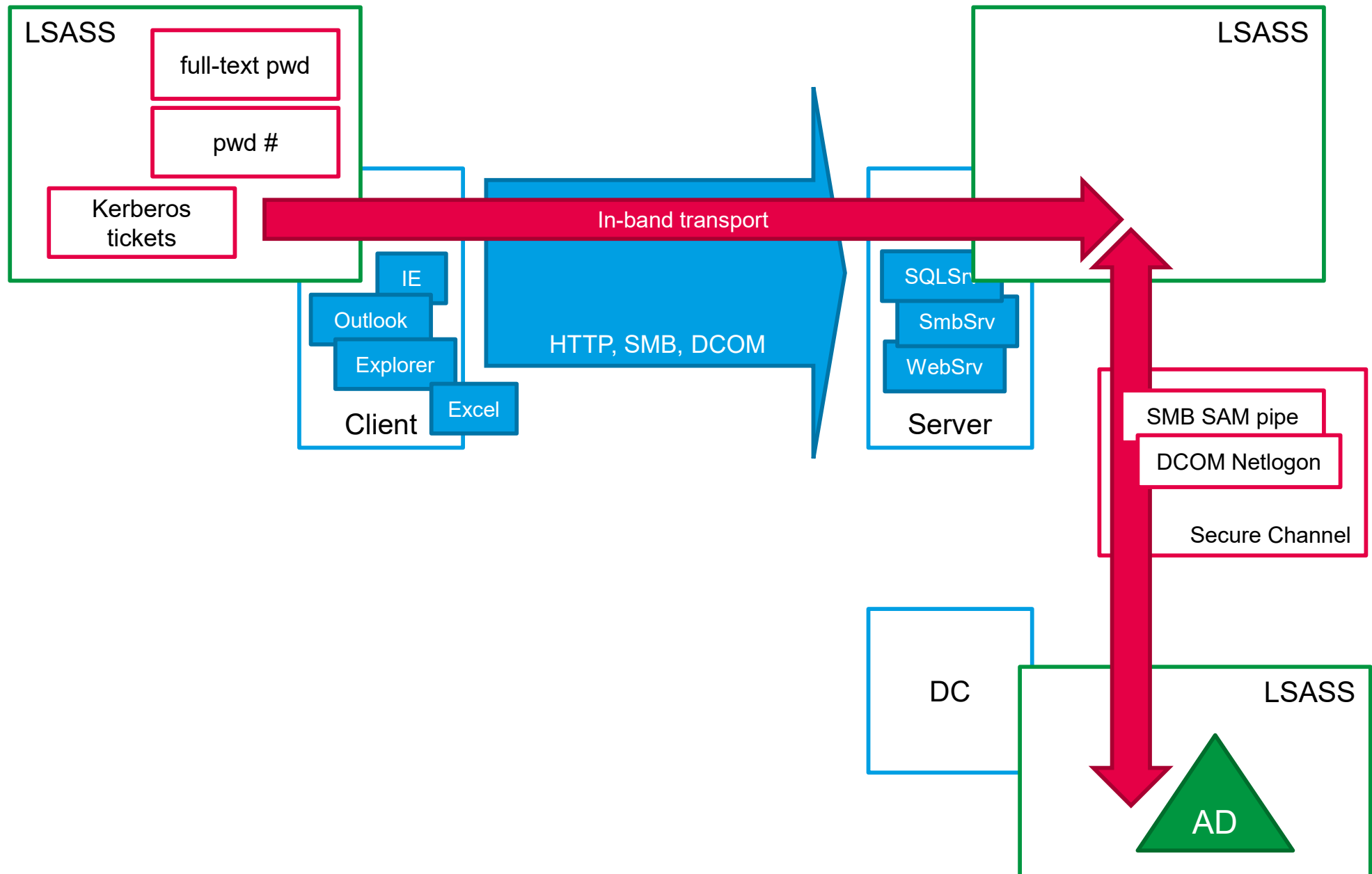
Client tools should not obtain full-text passwords on SSO



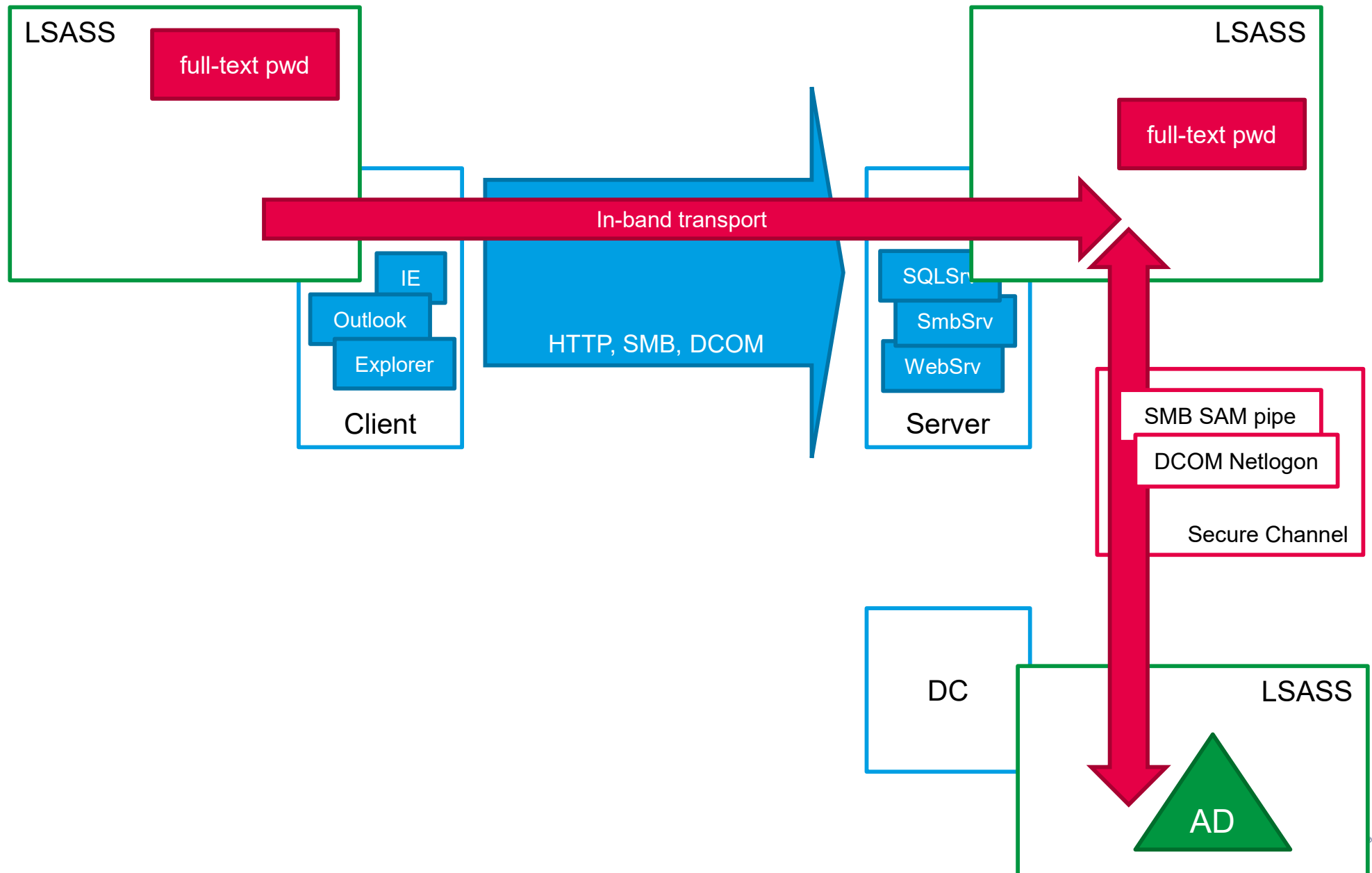
LSASS (local security authority sub system)

- Trusted security subsystem
- Accepts logon credentials from CTRL-ALT-DEL
 - GINA.DLL
 - Credentials provider .DLL since Windows Vista+
- Validates credentials with local SAM or with remote DC
- Works as a trusted client-server service
- HKLM\System\CCS\Control\LSA
- Computes **hashes** and/or stores **full-text** credentials and **tickets** for SSP (Security Support Provider) packages
 - full-text - wdigest, tspkg
 - MD4 - NTLM (msv1_0), Kerberos for RC4/DES
 - SHA-1 - Kerberos for AES

LSAS (local security authority sub system)



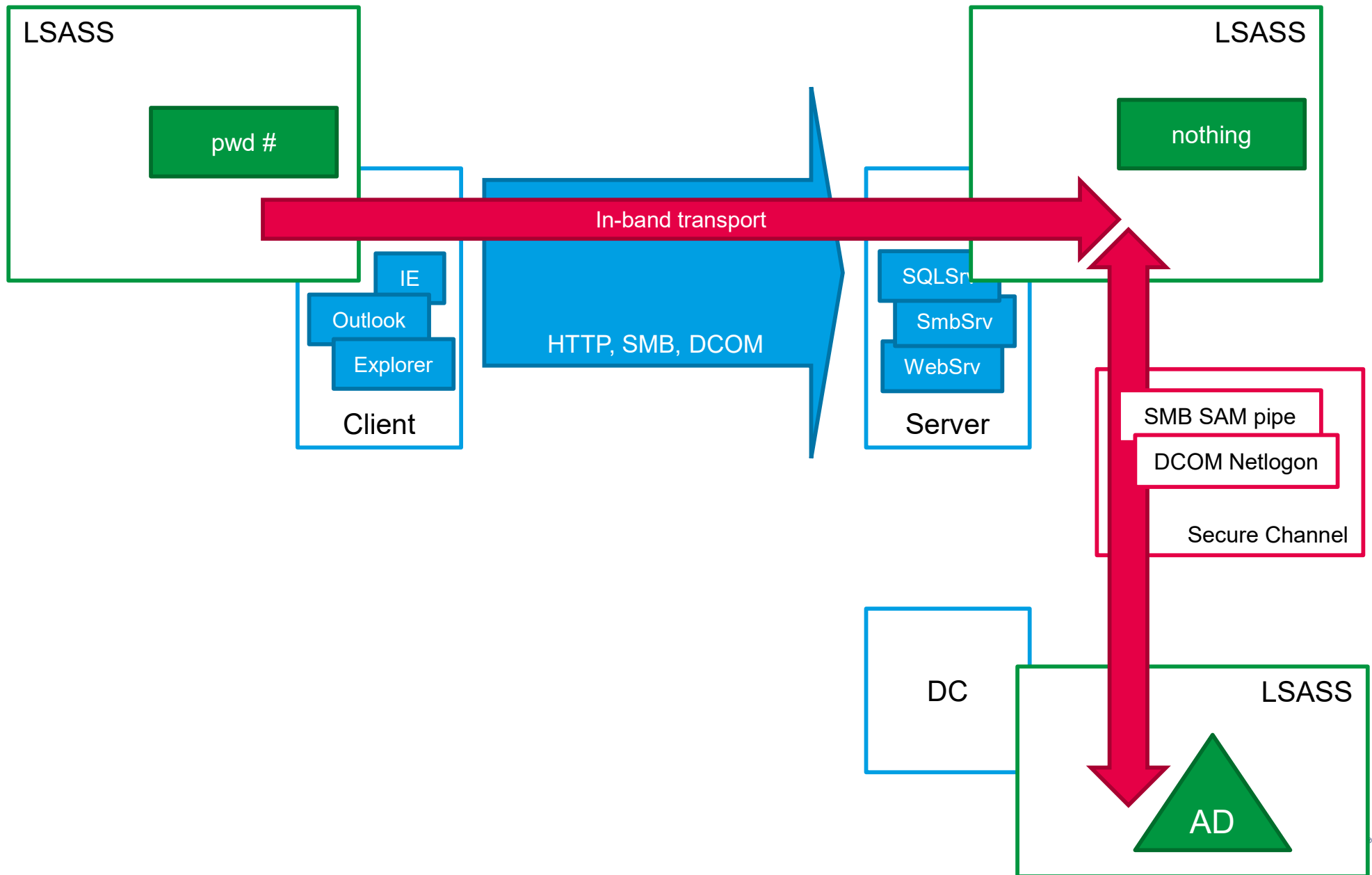
Server LSASS caches "basic" passwords



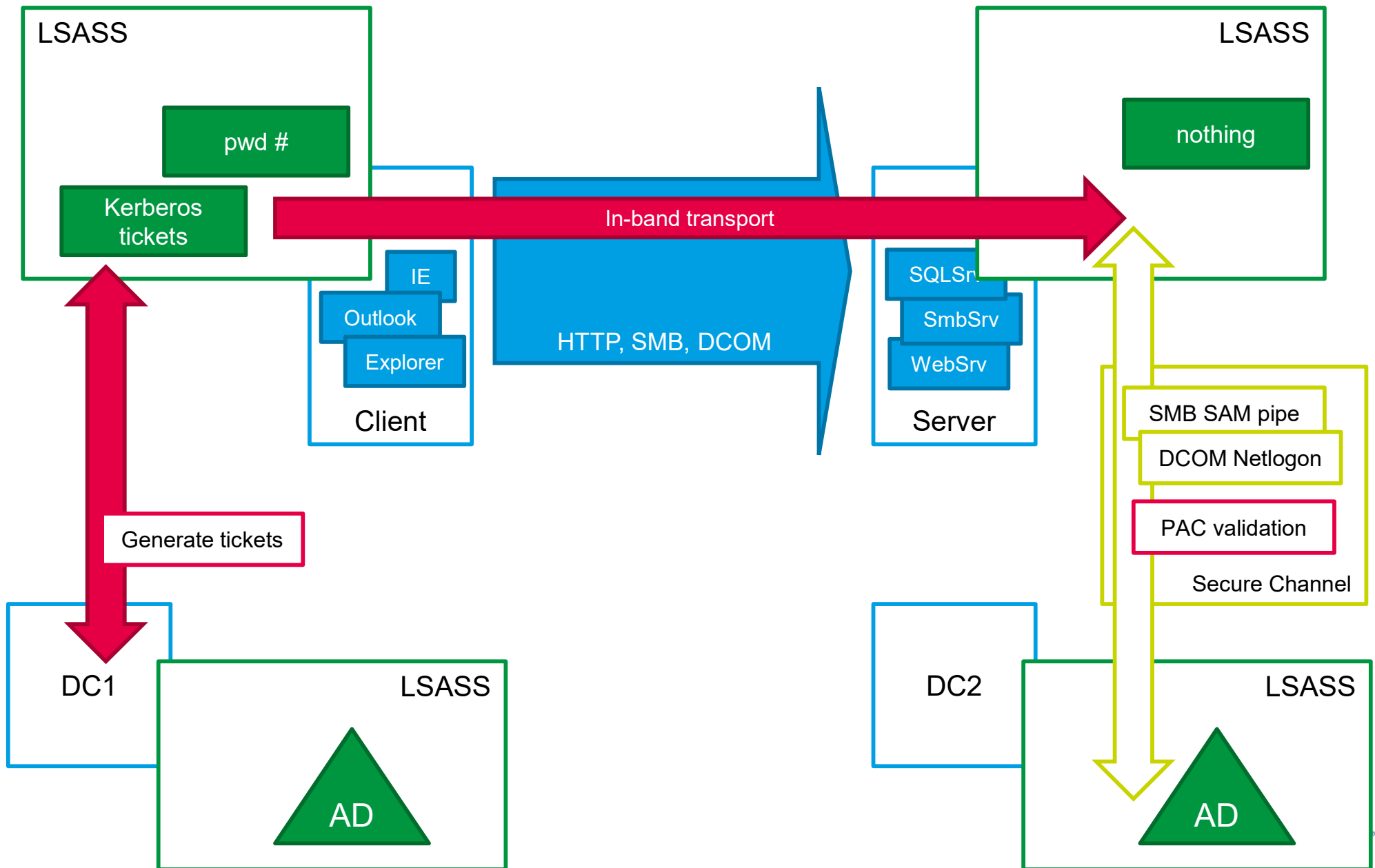
LSASS default secret storage in RAM

...	password
Windows 2000	lm#
Windows XP	md4#
Windows 2003	Kerberos tickets
Windows 2008	password
Windows Vista	lm#
Windows 2008 R2	md4#, sha1#
Windows 7	Kerberos tickets
Windows 2012	
Windows 8	
Windows 2012 R2	md4#, sha1#
Windows 8.1	Kerberos tickets
Windows 10	
Windows 2016/2019	
Windows 2025	md4#, sha1#, sha256#
...	Kerberos tickets

Cannot cache NTLM or Schannel



Kerberos in detail



Secure channel

- LSASS to LSASS communication
 - authenticated and signed/sealed by MACHINE\$ password
- SMB named pipe or DCOM
 - 2003- prefers SMB (TCP 445)
 - Vista/2008+ prefers DCOM (TCP 135 + DCOM???)
- Performs many security related operations
 - **SID** translation
 - **NTLM** and **SChannel** pass-through authentication
 - **PAC validation** in certain **Kerberos** scenarios
 - computer password changes
 - user password changes in backward compatible scenarios

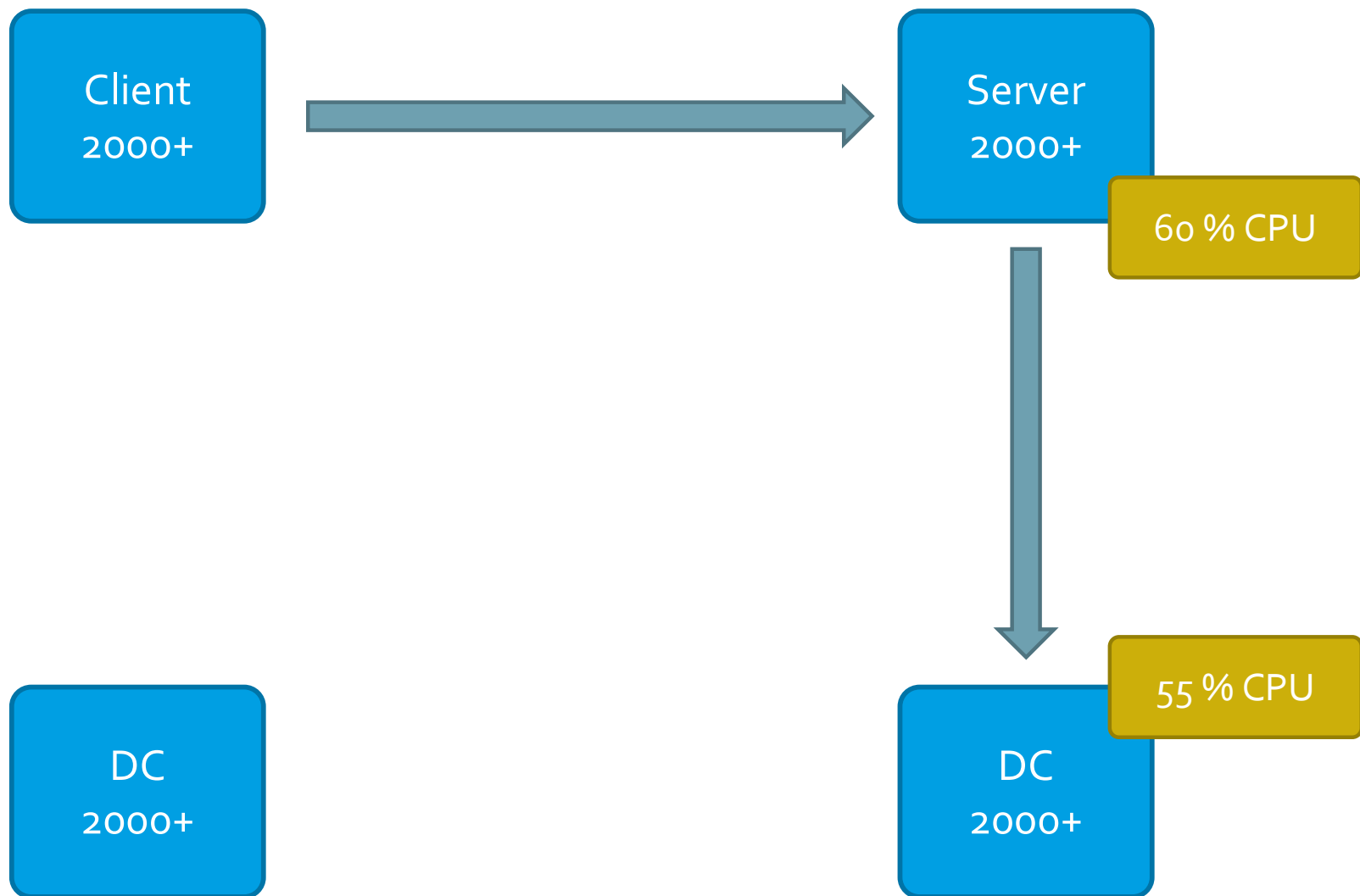
Secure channel DCOM/TCP port on DC

- On DCs
- HKLM\System\CCS\Services\Netlogon\Parameters
 - DCTcpipPort = DWORD
 - restart DC
- MaxConcurrentApi = DWORD
- 1-10, 2008 R2 SP1 default 100, max. 150 (KB2688798)
- 40 seconds timeout

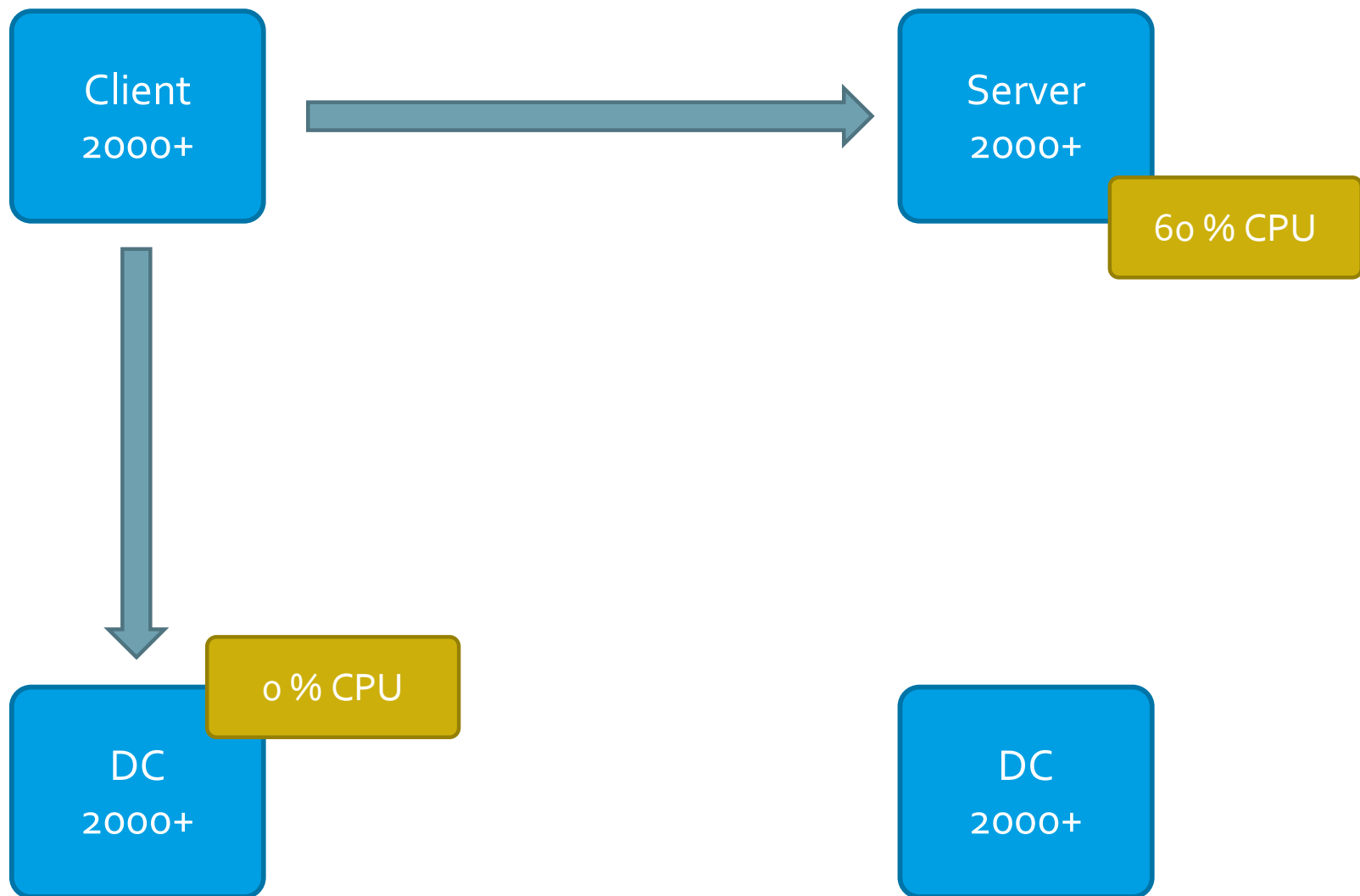
IIS basic authentication cache

- On IIS web servers
- Applies only for basic authentication credentials
- By default 15 minutes
- HKLM\System\CCS\Services\InetInfo\Parameters
 - UserTokenTTL = DWORD = seconds
 - case sensitive!

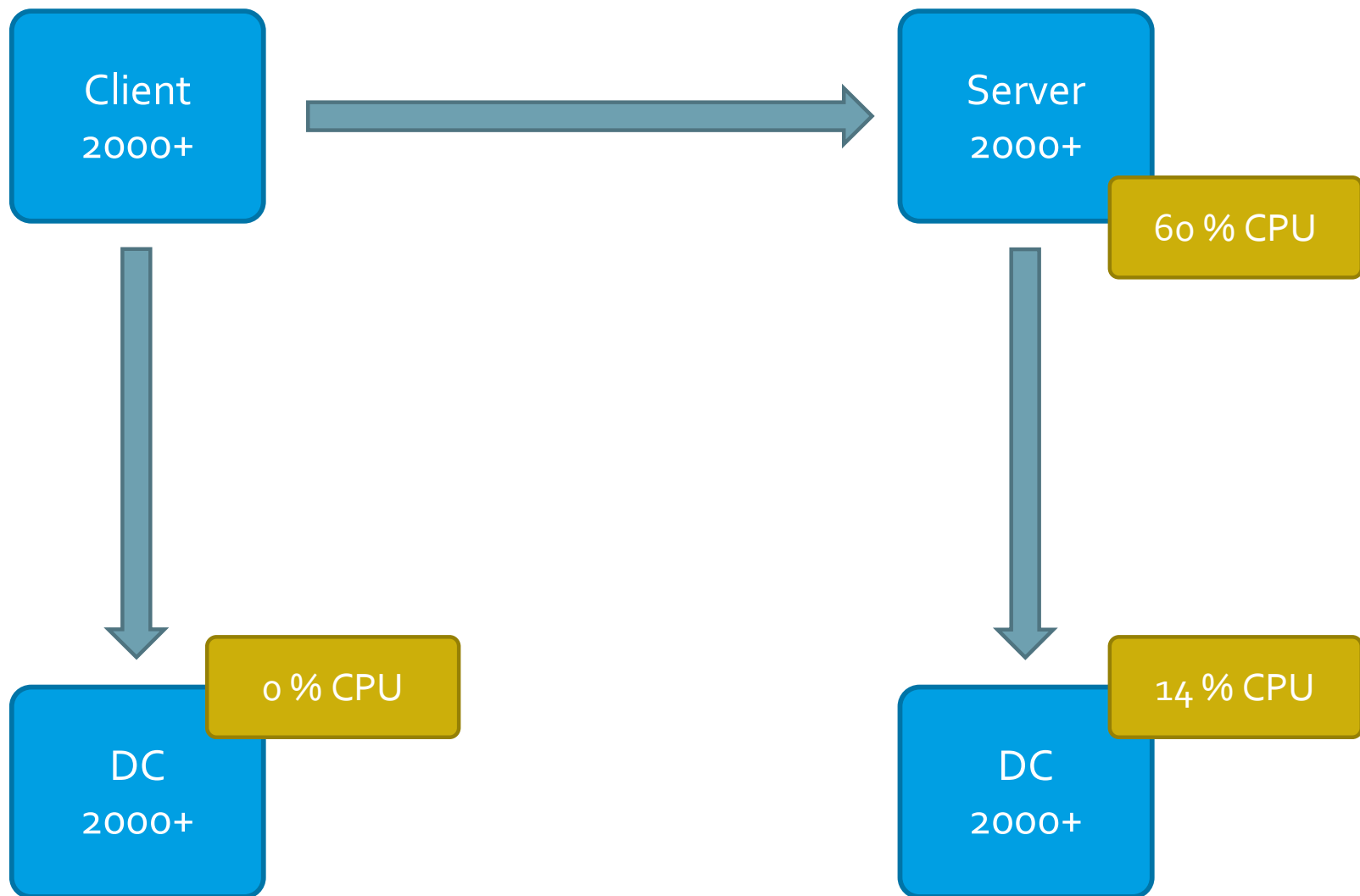
NTLM network logon performance



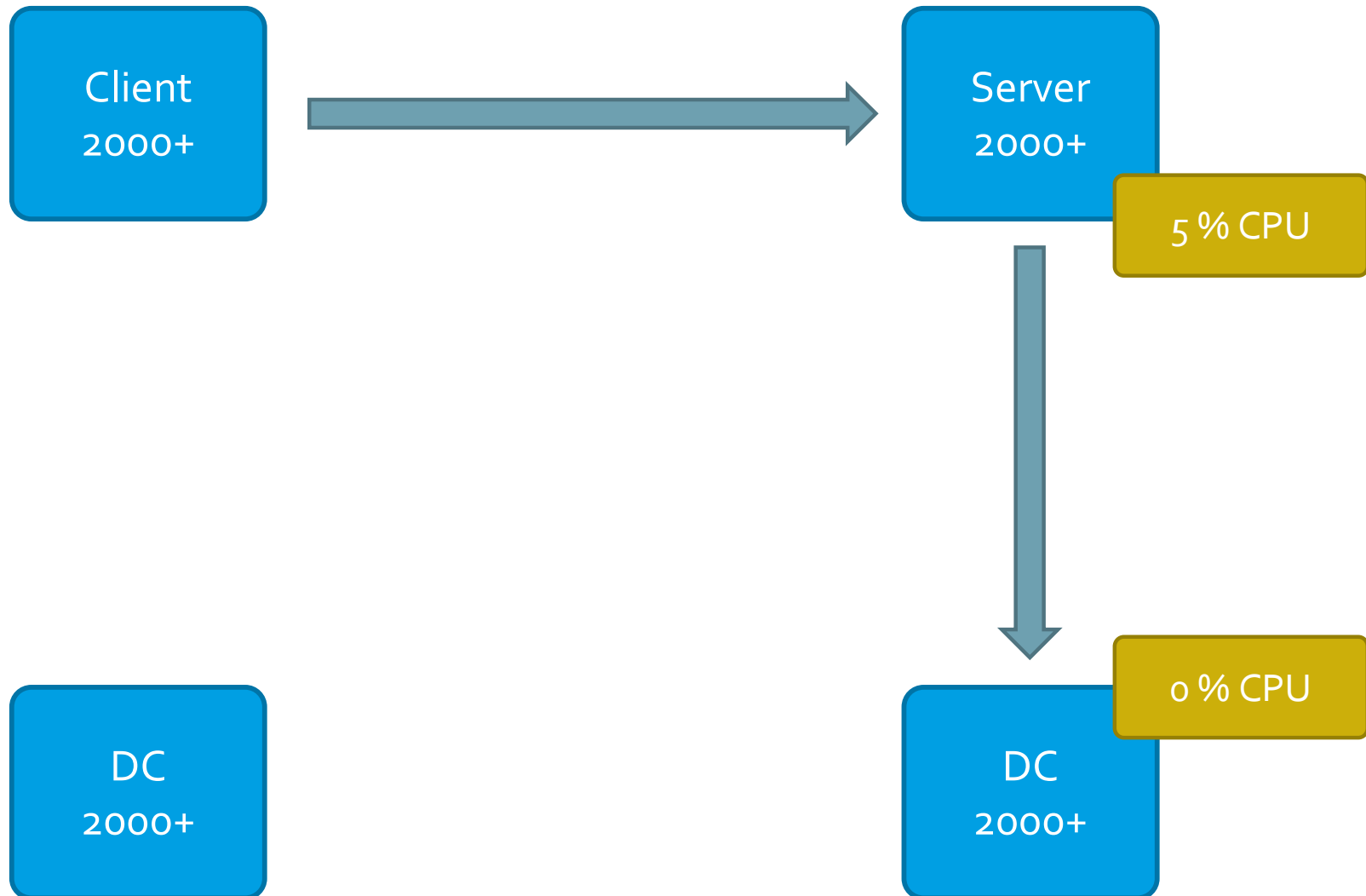
Kerberos network logon, no PAC validation



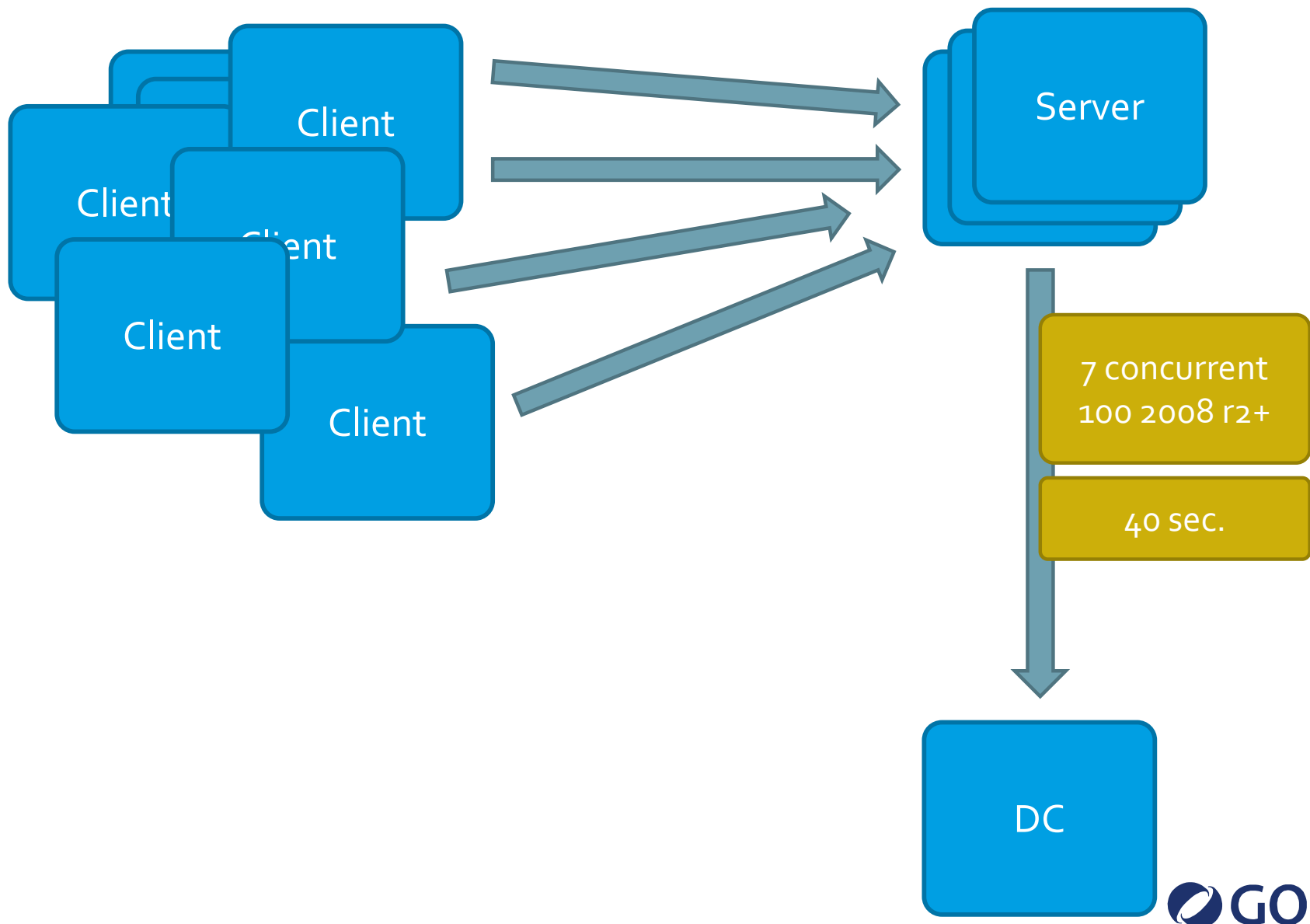
Kerberos network logon with PAC validation



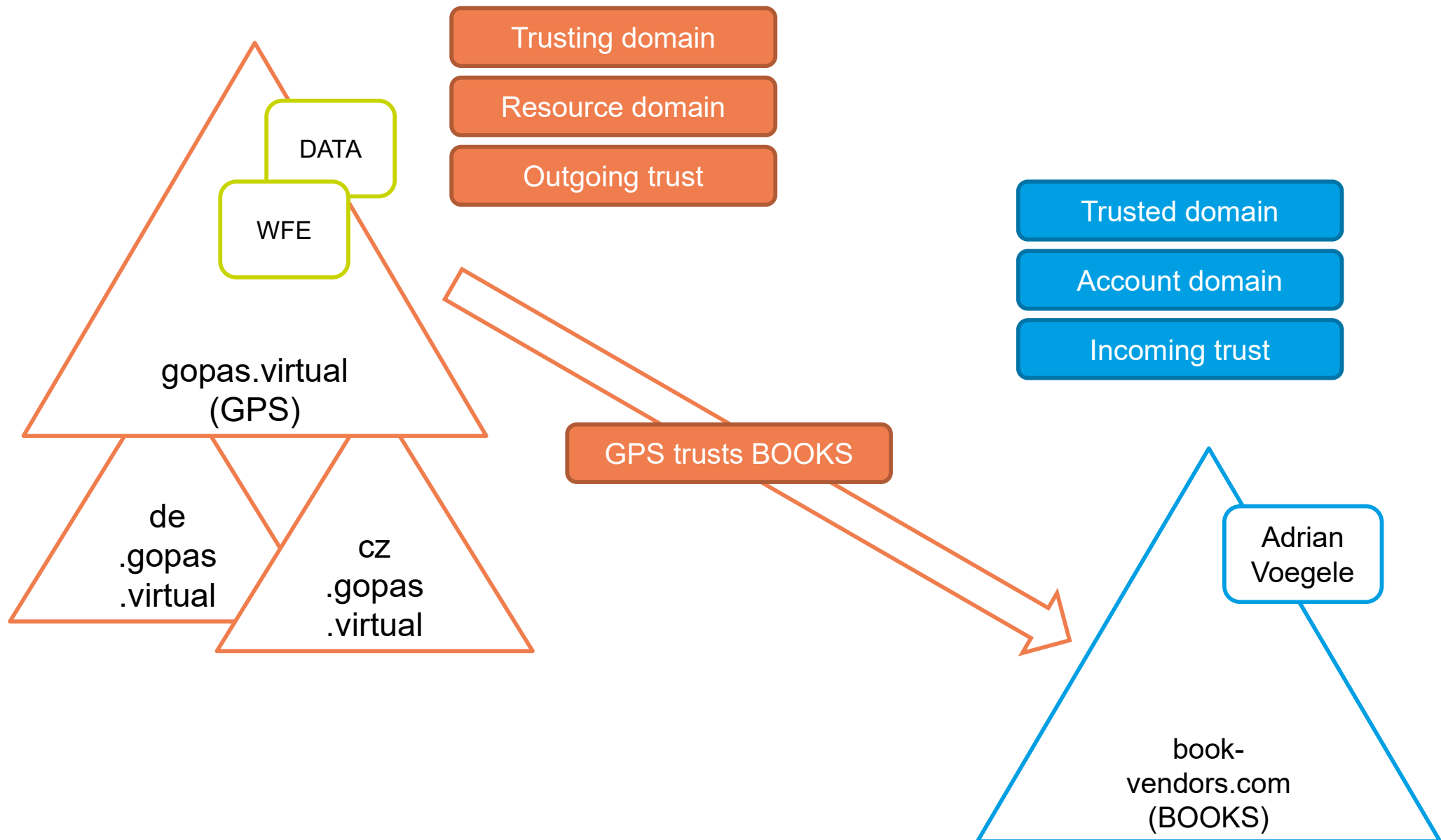
Basic authentication

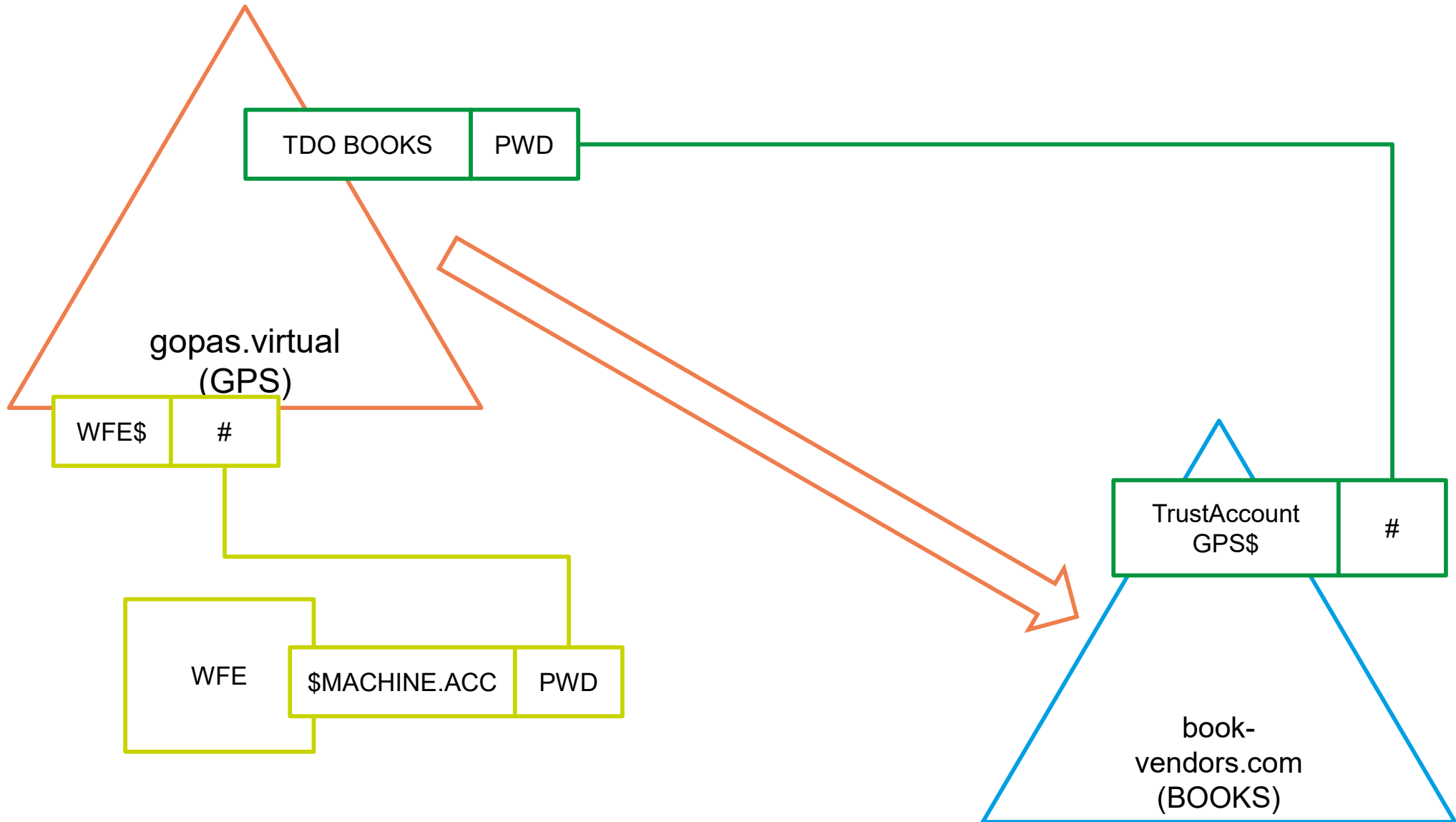


Secure channel and NTLM performance issues



GOPAS trusts BOOKS

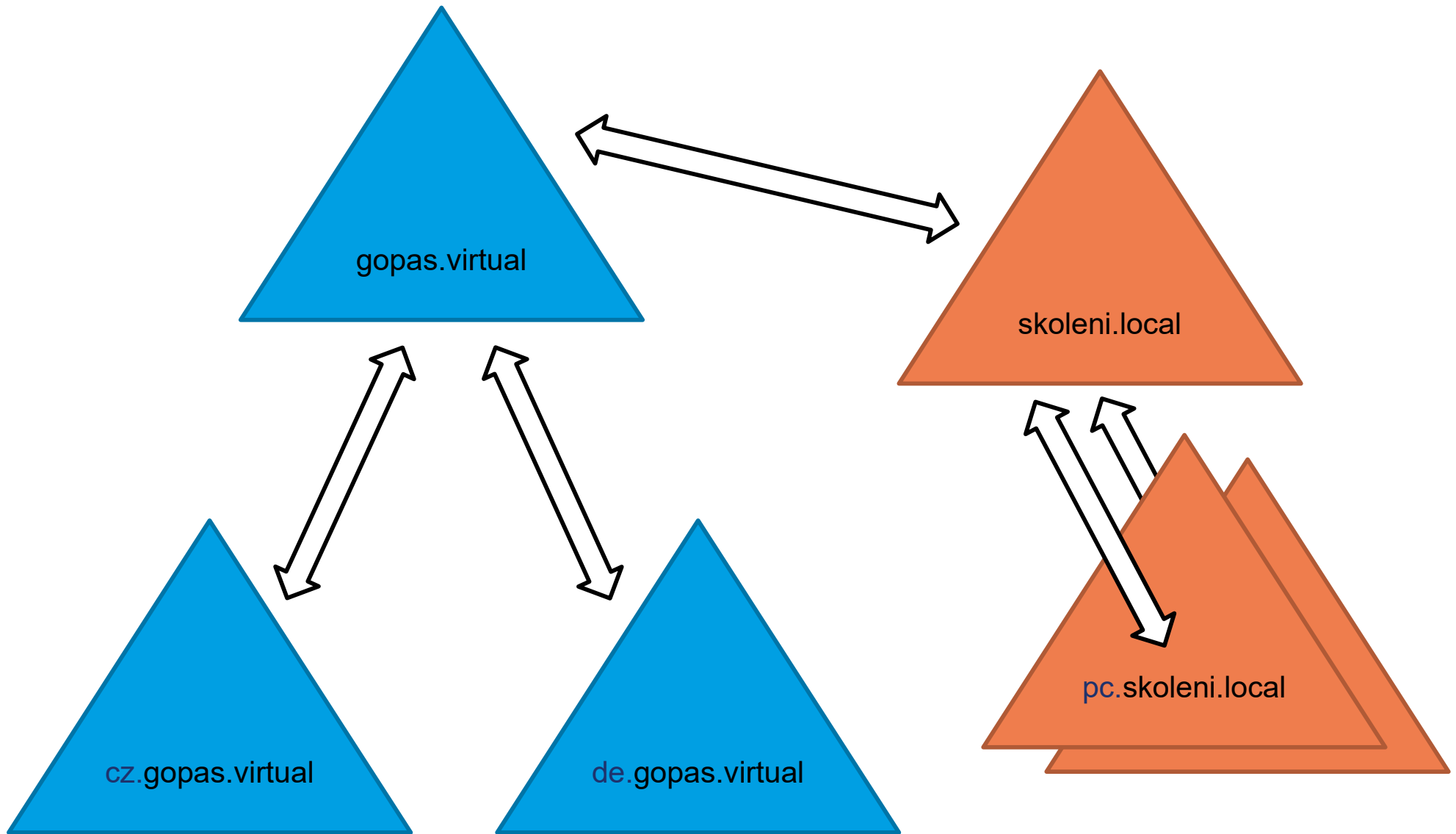




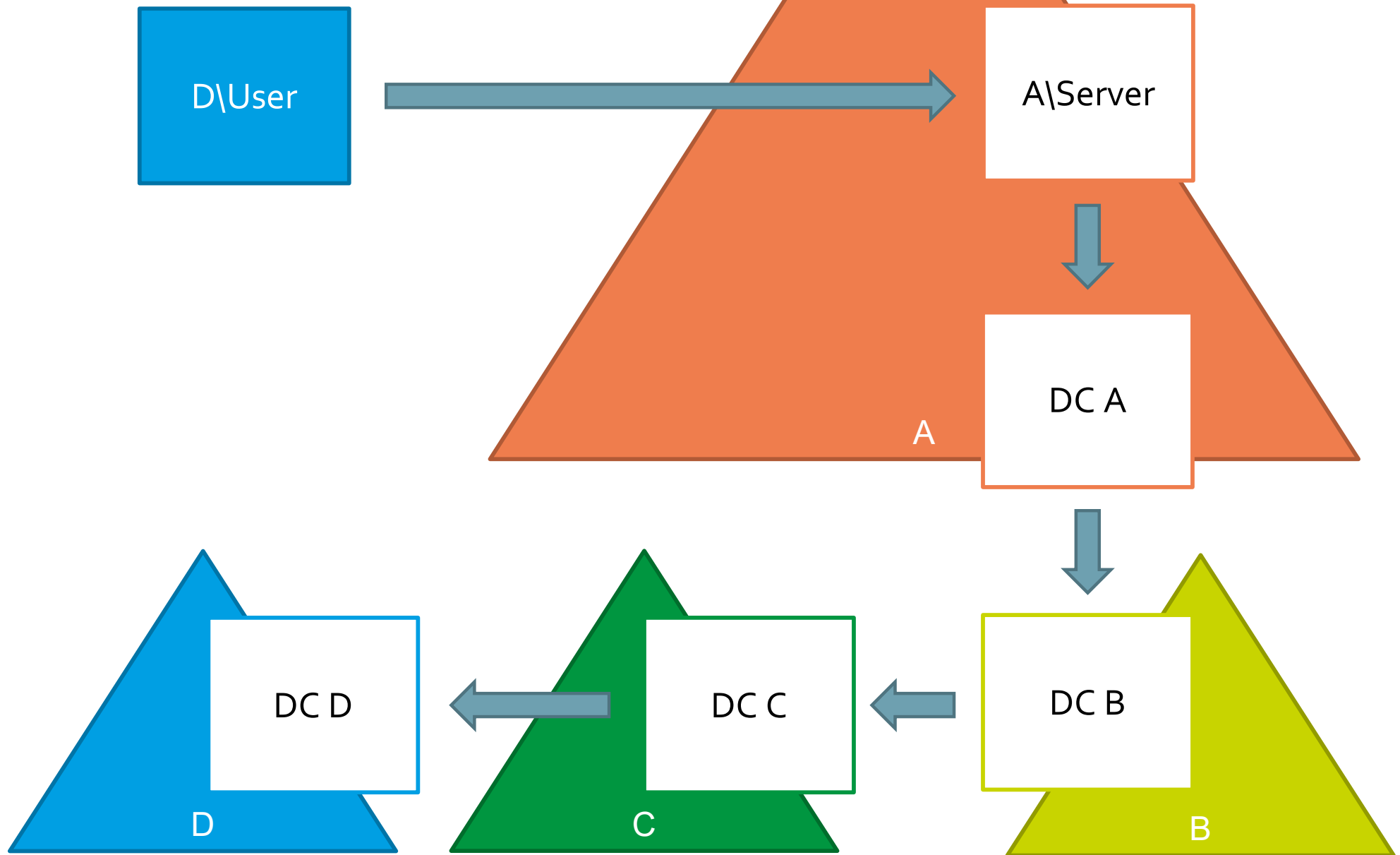
Trust account and TDO

- **user** object DOMAIN\$ in CN=Users
 - sAMAccountType = 805306370
- **trustedDomain** object in CN=SYSTEM
 - plus LSASS global secret with full-text password

Trusts within a single forest **gopas.virtual**



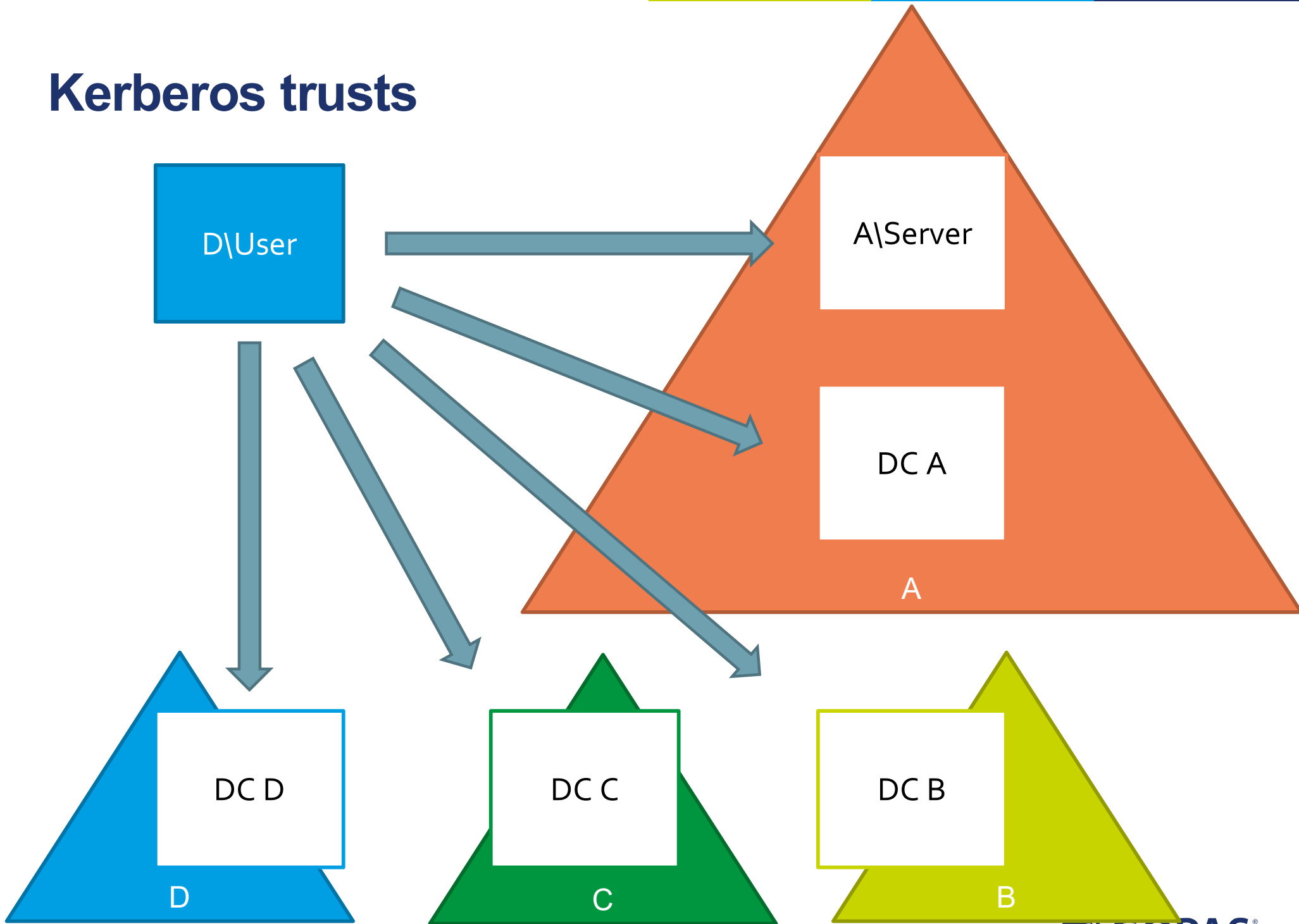
NTLM trusts (pass-through)



NTLM pass-through trust requirements

- TCP and DNS
 - at least adjacent DCs over the virtual trust-links
- RTT (round-trip-time) as fast as possible

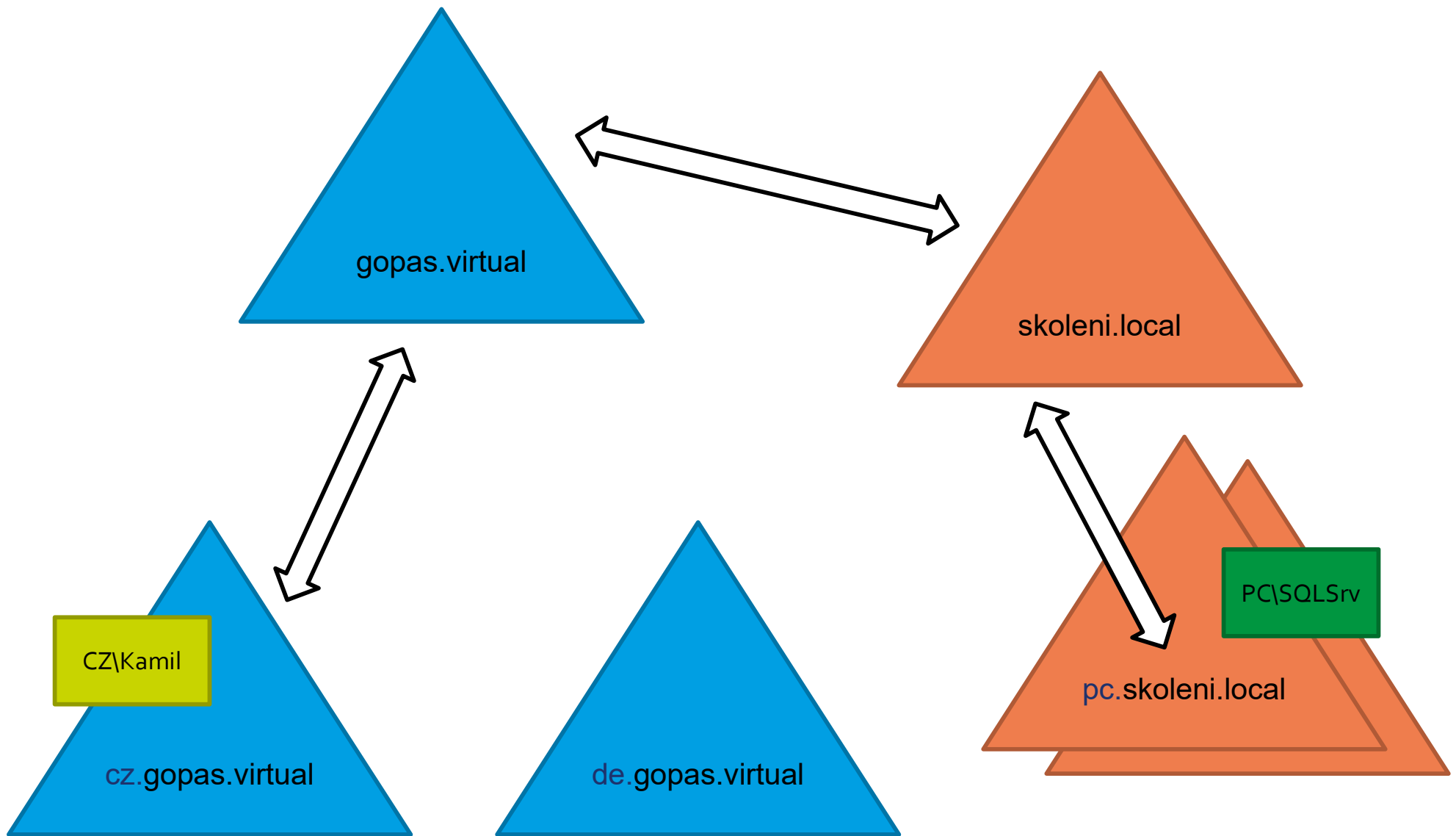
Kerberos trusts



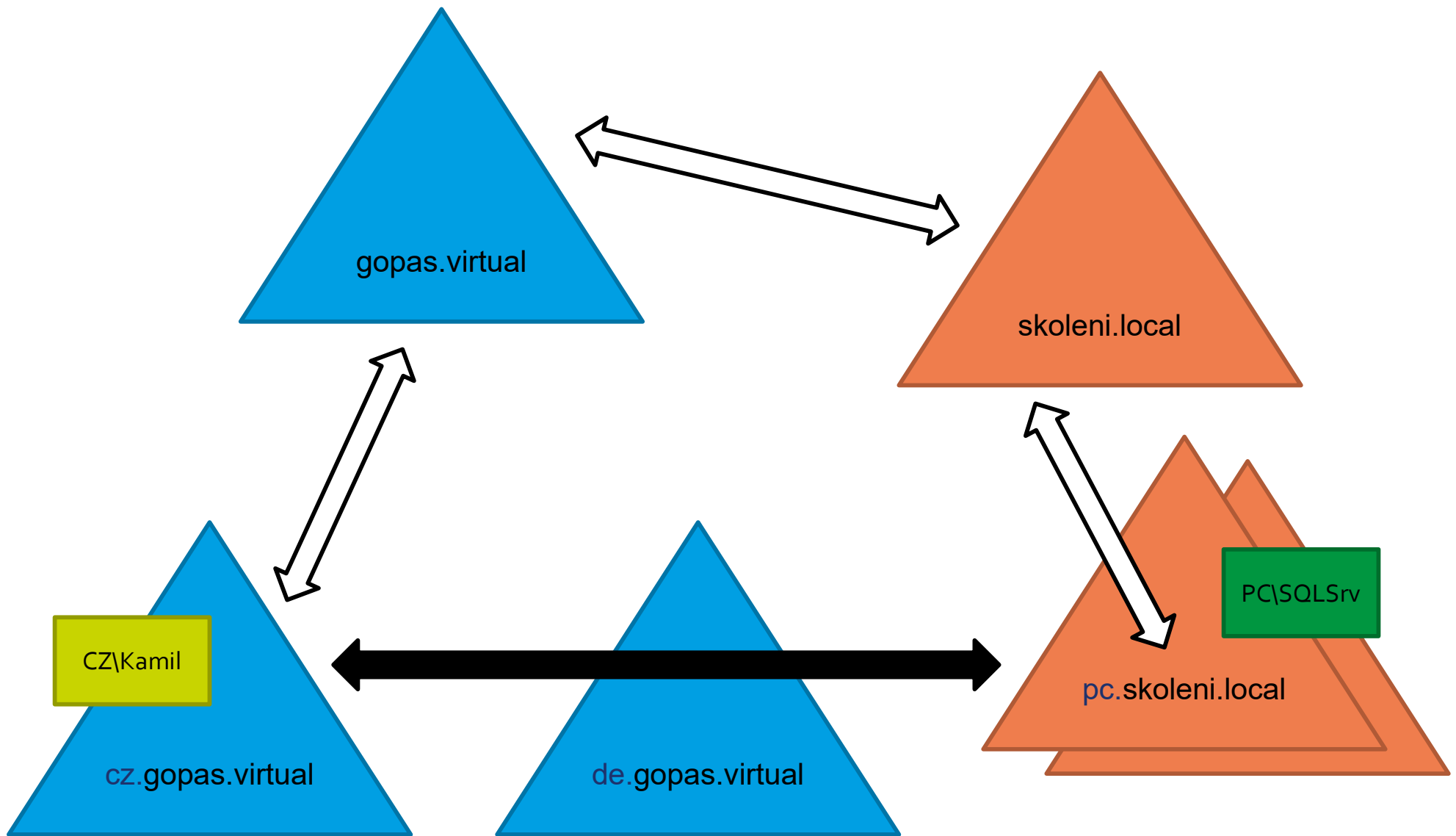
Kerberos trust requirements

- TCP and DNS
 - any client vs. any DC from any domain

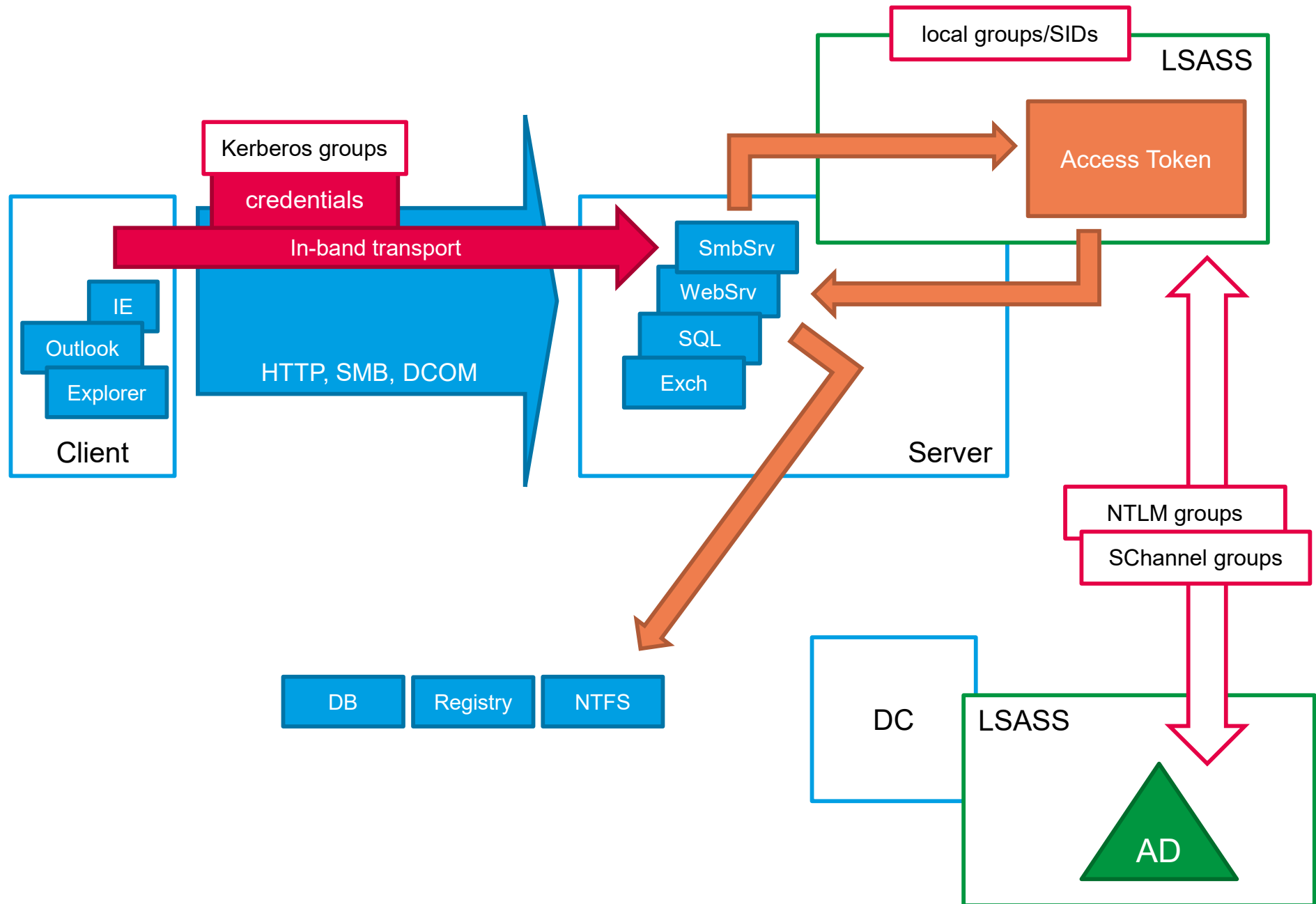
Slow authentication over multiple trusts



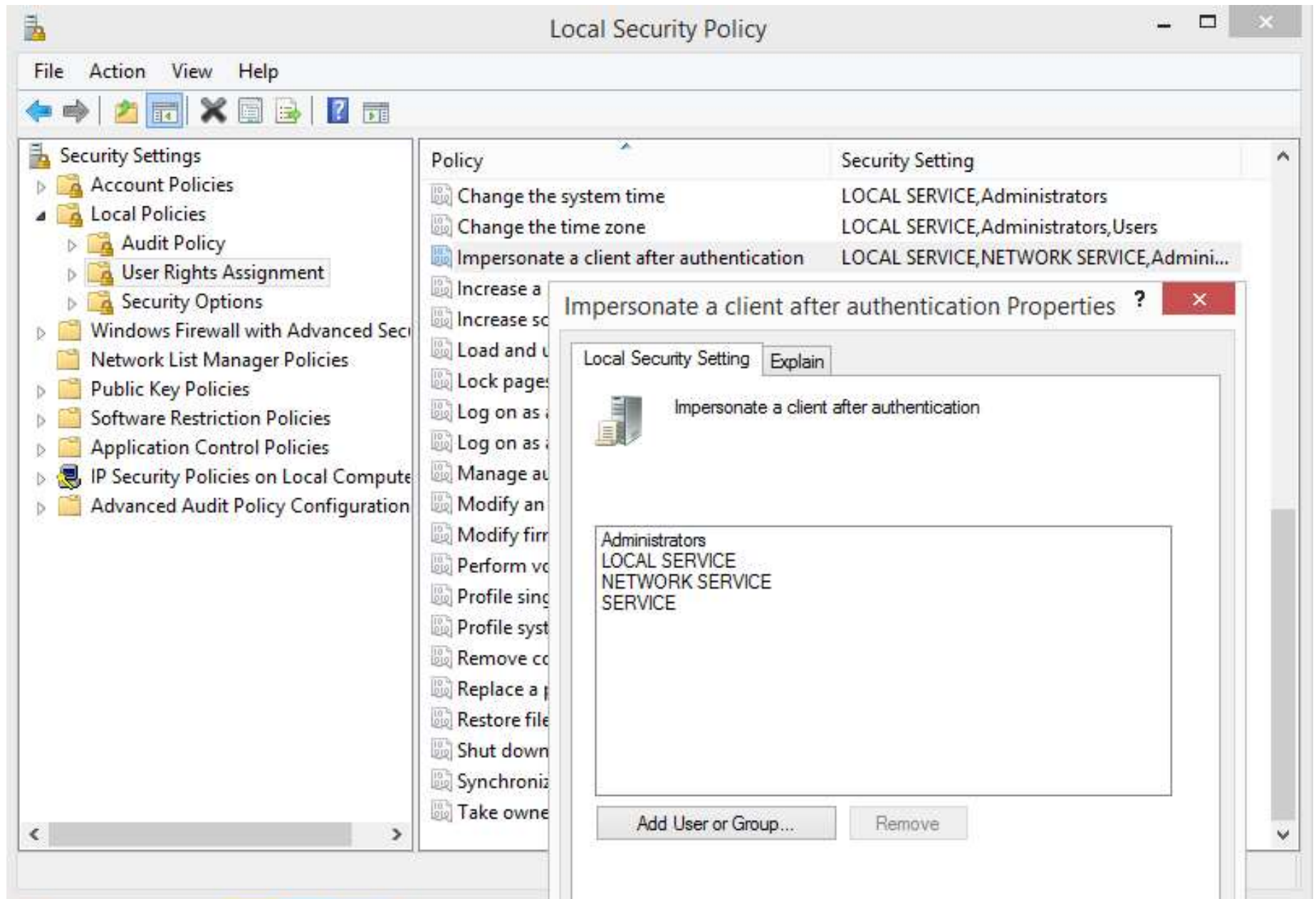
Shortcut trusts to speed up authentication



Impersonation and Access Token



User right: Impersonate client after authentication (SeImpersonatePrivilege)



IIS apppools vs. IIS_IUSRS implicit group injection

Impersonate a client after authentication Properties

Local Security Setting Explain

Impersonate a client af

Administrators
IIS_IUSRS
LOCAL SERVICE
NETWORK SERVICE
SERVICE

IIS_IUSRS F

General



IIS_IUSRS

Description:

Built-in group used b

Members:



Process Explorer - Sysinternals: www.sysinternals.com [SVCK\sp-adm

File Options View Process Find Users Help

Process	CPU	Private Bytes	Working Set	PID	User Name
---------	-----	---------------	-------------	-----	-----------

svchost.exe
w3wp.exe
w3wp.exe
w3wp.exe
w3wp.exe
w3wp.exe
c2wtschost.exe
DistributedCacheS
mssearch.exe
mssdmn.exe
mssdmn.exe
svchost.exe
svchost.exe
rdpclip.exe
svchost.exe
VSSVC.exe
msdtc.exe
OWSTIMER.EXE
lsass.exe
winlogon.exe
dwm.exe
explorer.exe
inetMgr.exe

w3wp.exe:14968 Properties

.NET Assemblies

.NET Performance

Strings

Image

Performance

Performance Graph

Disk and Network

GPU C

Threads

TCP/IP

Security

Environm



User: SVCK\svc-iis-finance

SID: S-1-5-21-2673496538-4043721787-142770761-1180

Session: 0

Logon Session: 12ec53ec

Virtualized: No

Protected: No

Group

Flags

Authentication authority asserted identity

Mandatory

BUILTIN\IIS_IUSRS

Mandatory

BUILTIN\Users

Mandatory

CONSOLE LOGON

Mandatory

Everyone

Mandatory

IIS APPPOOL\finance AppPool

Mandatory

LOCAL

Mandatory

Mandatory Label\High Mandatory Level

Integrity

NT AUTHORITY\Authenticated Users

Mandatory

NT AUTHORITY\BATCH

Mandatory

NT AUTHORITY\Claims Valid

Mandatory